

Informe de Auditoría y Evaluación de Impacto (EIPD) - Fase 1: OmniSalud

Análisis de Contexto, Licitud y Descripción Sistemática del Tratamiento

Proyecto: Laboratorio de Cumplimiento OmniGroup
Unidad de Negocio: OmniSalud (Servicios Clínicos y Telemedicina)
Consultor Líder: Gonzalo Vega Batyi, Abogado / DPO
Referencia Normativa: Ley 21.719 (Protección de Datos), Ley 21.663 (Ciberseguridad)
Marco Metodológico: ISO 31000:2018 | ISO 27001 | ISO 27701 | Modelo AEPD/EDPB

Nota de Confidencialidad: Este documento forma parte del repositorio de cumplimiento normativo del Holding OmniGroup. Su contenido detalla la Fase 1 del proceso de gestión de riesgos según el estándar internacional ISO 31000. Omnisalud ha sido designado como Operador de Importancia Vital (OIV) por la Agencia Nacional de Ciberseguridad (ANCI).

1. Alcance y Contexto Organizacional (ISO 31000: 6.3)

En esta fase inicial, definimos los parámetros externos e internos que rigen el tratamiento de datos en **OmniSalud**. Como abogados estrategas, nuestro enfoque se centra en la gobernanza y la licitud, no en la implementación física de la red.

1.1 Estructura de Gestión de la Unidad

Para garantizar el principio de **Responsabilidad Proactiva (Accountability)**, la unidad se organiza bajo el siguiente esquema de segregación de funciones:

Cargo	Función en el SGPI (ISO 27701)	Responsabilidad Principal
Director de Unidad	Enlace Estratégico	Reporte directo al Holding y toma de decisiones presupuestarias para cumplimiento.
Administrador de Unidad	Gestor de Privacidad	Supervisión diaria de los manuales de procedimiento y control de acceso a datos.
Cuerpo Operativo (4)	Operadores de Datos	Ejecución de servicios de telemedicina y registro de fichas bajo estricta reserva legal.

2. Descripción Sistemática del Tratamiento (EDPB 1.1)

Siguiendo el estándar del **Comité Europeo de Protección de Datos (EDPB 2026)**, caracterizamos la operación de tratamiento actual:

2.1 Categorización de Activos de Información

- **Nombre del Dataset:** `omnisalud_clientes.csv`
- **Naturaleza de los Datos:** Categorías especiales de datos (Datos Sensibles de Salud).
- **Categorías de Interesados:** Pacientes y usuarios de servicios de telemedicina.

2.2 Inventario Técnico-Jurídico de Campos

- **Identificadores:** `ID_Interno` (Persistente), Nombre completo.
- **Datos Sensibles:** `Patologia_Cronica`, historial de diagnósticos, prescripciones médicas.
- **Contexto:** Los datos se capturan mediante plataformas digitales y se integran en un servidor centralizado del Holding sin medidas de seudonimización previas.

3. Análisis de Licitud y Bases Legales (EDPB 2.1)

Como expertos en cumplimiento, evaluamos la conformidad del tratamiento con la **Ley 21.719** de Chile:

3.1 Bases de Licitud Invocadas

1. **Ejecución de Contrato:** Tratamiento necesario para la prestación de servicios de salud.
2. **Cumplimiento de Obligación Legal:** Registro de fichas clínicas según normativa sanitaria.

3.2 El Problema de la "Contaminación de Finalidad"

Hallazgo de Auditoría: Se detecta que el identificador `ID_Interno` es compartido con la filial de Seguros (**OmniRetail**) para fines de perfilamiento comercial.

- **Infracción Detectada:** Vulneración del **Principio de Finalidad (Art. 9, Ley 21.719)**. El consentimiento del paciente para fines clínicos no ampara el uso comercial o actuarial por parte del Holding.

4. Diagnóstico de Gobernanza (Gap Analysis)

Bajo la óptica de la **ISO 27001 (SGSI)** y **ISO 27701 (SGPI)**, se identifican las siguientes ausencias críticas en OmniSalud:

- **Falta de Protocolos:** No existe un manual que regule la interacción entre el Administrador de la Unidad y el área de TI del Holding.
- **Inexistencia de Manuales de Usuario:** El cuerpo operativo no ha recibido directrices reglamentarias sobre la prohibición de exportación de datos sensibles.
- **Vulnerabilidad de Ciberseguridad (Ley 21.663):** Los datos sensibles viajan por el repositorio del Holding en texto claro, sin protocolos de cifrado robustos que protejan la infraestructura crítica de salud.

5. Conclusión Preliminar de la Fase 1

La unidad **OmniSalud** opera bajo un escenario de **Ilícitud de Tratamiento Secundario**. Aunque el tratamiento primario (salud) es lícito, el flujo de datos hacia el Holding carece de base legal y medidas de seguridad organizativas.

Próximo Hito: Evaluación y Calificación de Riesgos según el método de impacto de la AEPD (Fase 2).
